



University of Glasgow | School of Computing Science

CSC3106 Cyber Security Fundamentals Mini-Project

Group Y

Name	GUID	SIT ID
Goh Qi Xun	3070608G	2400819
Jabier Ho Wei Le	3070677H	2402063
Kong Yong Shu Yuki	3070582K	2400527
Yip Jun Wei	3070612Y	2400827

1. Data-Driven Authentication Log Analysis	3
1.1 Preliminary Findings	3
1.2 Security Question and Asset Framing	3
1.3 Python-Verified Findings and Visualisations	3
1.3.1 Finding 1 - Cluster of IPs dominating failed attempts	3
1.3.2 Finding 2 - Dominant source rotates	4
1.3.3 Failed attempts target generic and privileged-sounding accounts	4
1.3.4 One high-volume failure source achieved a successful login	5
1.4 Risk summary	5
1.5 Recommended initial response	5
2. Technical Defensive Response	6
2.1 Selected risk finding	6
2.2 Supporting evidence and prioritisation	6
2.3 Proposed defensive response	6
2.4 Expected security benefits	7
2.5 Limitations and residual risks	8
Appendix	9
Appendix A - Full Event Classification Counts	9
Appendix B - Asset-Focused Risk Matrix	10
Appendix C - AI Use Declaration	12

1. Data-Driven Authentication Log Analysis

1.1 Preliminary Findings

AI assistance was used to generate preliminary findings and identify areas for review. All figures, visualisations and interpretations are based on Python-verified analysis of the supplied OpenSSH log, 4_auth_log.txt, using analysis.py.

1.2 Security Question and Asset Framing

This section addresses the following security question:

Does authentication activity on backup01 indicate attempted or potentially successful unauthorized access, and what initial response is proportionate to the risk to the organisation's backup capability?

The asset in scope is SSH authentication and administrative access to backup01, including the backup data and restoration capability it supports. It is high-value because unauthorized access could expose, alter or delete recovery data, modify backup configurations, or reduce the organisation's ability to recover from an incident.

The dataset contains 12,000 OpenSSH log lines for the single host backup01 across 6-12 July. The following analysis therefore supports findings about this host and time period only.

1.3 Python-Verified Findings and Visualisations

Python classified all 12,000 log lines into nine event types without loss or double-counting (Appendix A), while extracting usernames, source IPs and failed/accepted activity. The log recorded 5,176 failed-password, 1,859 accepted-password, 751 invalid-user and 640 maximum-attempt events. This volume and pattern indicate repeated SSH-guessing activity, unlikely to be explained by normal user error alone.

1.3.1 Finding 1 - Cluster of IPs dominating failed attempts

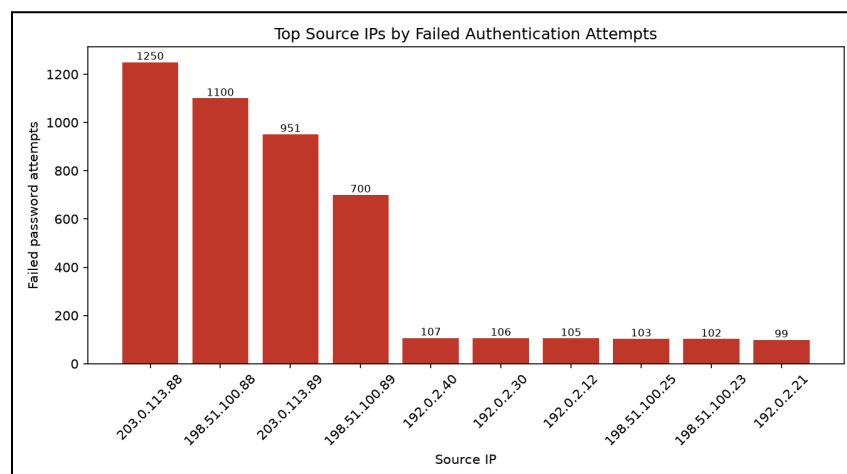


Figure 1: Top source IPs by failed authentication attempts

Figure 1 shows that the failed authentication activity was highly concentrated. The four leading sources, 203.0.113.88 (1,250), 198.51.100.88 (1,100), 203.0.113.89 (951) and 198.51.100.89 (700), generated 4,001 failures, or 77.3% of the total. This concentration suggests automated or coordinated attempts rather than ordinary login errors. However, IP addresses alone cannot identify the operator because they may be shared, proxied or anonymised.

1.3.2 Finding 2 - Dominant source rotates

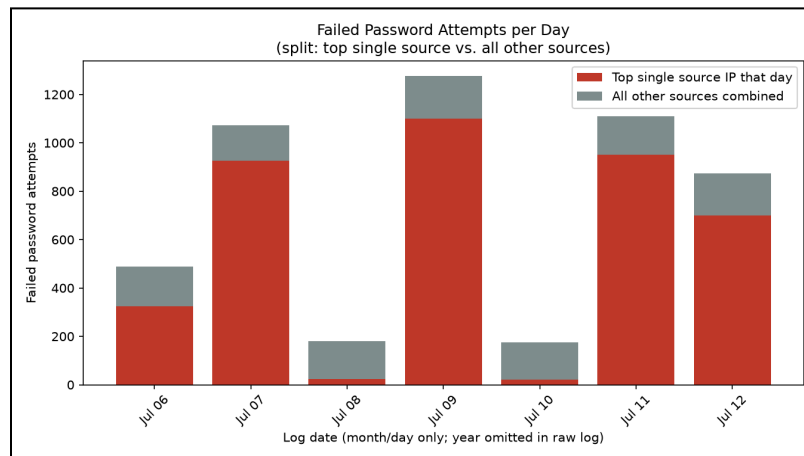


Figure 2: Daily failed-password attempts

Figure 2 shows daily failed-password attempts, separated into the highest-volume source on each day and all other sources. The highest-volume days were 7 July (1,072 failures), 9 July (1,276), 11 July (1,111) and 12 July (873). Together, these accounted for 4,332 failures, or 83.7% of the total.

The daily pattern supports a burst-based interpretation. On the highest-volume days, one source dominated the failures rather than activity being evenly distributed across unrelated sources. This strengthens the assessment that backup01 experienced concentrated authentication pressure.

1.3.3 Failed attempts target generic and privileged-sounding accounts

All 5,176 failed-password events mapped to 10 usernames. The most targeted accounts were backup (1,552), root (1,048), admin (589), deploy (366), postgres (336), oracle (331) and ops (237). These seven accounts accounted for 4,459 failures, or 86.1% of the total. The remaining three individual users (J.singer, J.maguire and Arun) accounted for 717 failures, or 13.9%.

This distribution indicates targeting of administrative, service and backup-related accounts. The high number of attempts against backup and root is therefore more significant for backup01 than the same number of failures against ordinary user accounts. However, failed attempts do not prove compromise, and the log does not show whether each account was enabled or authorised for remote access.

1.3.4 One high-volume failure source achieved a successful login

Cross-referencing failed and accepted logins showed that three of the four leading failure sources had no accepted login. The exception, 203.0.113.89, recorded 951 failures and one successful login to backup on 11 July at 03:08:19. The session was followed by `sudo /usr/bin/journalctl -n 200` executed as root. The same IP had previously made 311 failed attempts against backup.

Although the login may have been authorised, shared, anonymised or part of a controlled test, the combination of repeated failures, successful access and root-level activity makes it a priority for validation. Overall, the findings are consistent with automated password guessing or credential stuffing. The evidence supports the conclusion that backup01 faced substantial, concentrated authentication activity and that the accepted backup login requires urgent validation.

1.4 Risk summary

The asset-focused risk matrix is provided in Appendix B. The main risk is that an unauthorized party may have gained access through backup and then used root-level privileges to inspect, alter or remove backup data. This would affect confidentiality, integrity and recovery availability.

The second risk is operational disruption if the volume of failures affects administration, monitoring or recovery work. A third risk is future compromise through continued guessing or credential reuse, especially because backup, root, admin and deploy were repeatedly targeted.

The initial risk rating is high because the asset is critical, failed activity is concentrated, and one high-volume source is associated with an accepted backup login followed by root-level activity. The main uncertainty is whether that session was authorised.

1.5 Recommended initial response

The organisation should treat the accepted backup session from 203.0.113.89 on 11 July at 03:08:19 as a priority security alert while avoiding unsupported claims of confirmed compromise.

1. Preserve and correlate evidence. Retain authentication, sudo, audit, shell-history, network-flow and backup-application logs. Correlate the accepted session with user identity, source network, session duration, commands, files accessed and backup changes.
2. Validate authorisation and contain if needed. Confirm whether the backup login and root-level command were expected. If not, contain the source, rotate related credentials, and review privileged accounts.
3. Harden SSH access. Restrict SSH to a management network or VPN, disable password authentication where possible, enforce key-based access and MFA, and disable direct root login.
4. Improve detection and verify recovery. Alert on bursts, failures followed by accepted access, targeting of backup or root, and repeated maximum-authentication events. Verify backup integrity and perform a controlled restore test.

2. Technical Defensive Response

2.1 Selected risk finding

This response addresses R1, the risk that repeated and concentrated password attempts, potentially automated, against backup01 could lead to an unauthorised SSH login to the backup account, exposing sensitive backup data or enabling access to privileged system functions.

The asset considered is the backup01 host's SSH authentication service and its associated privileged accounts. This risk is assessed as having high likelihood and high impact. The likelihood is supported by the volume and concentration of authentication failures, while the potential impact is significant because the backup account is associated with sudo activity that executed commands as root.

2.2 Supporting evidence and prioritisation

As established in Part 1 (1.3.3 - 1.3.4), the backup account was the most targeted username (1,552 failed attempts), and four source IPs accounted for 77.3% of all failures. Source 203.0.113.89 is the most significant of these, generating 951 failures before an accepted login to the backup account followed by privileged sudo activity. The raw log records:

- Jul 11 03:08:19 backup01 sshd[2164]: Accepted password for backup from 203.0.113.89 port 59595 ssh2
- Jul 11 03:08:19 backup01 sshd[7367]: pam_unix(sshd:session): session opened for user backup by (uid=0)

The (uid=0) value identifies the privileged process that opened the session and does not, by itself, show that the backup user logged in as "root". The stronger evidence of privileged capability is the separate sudo record showing the account executing `/usr/bin/journalctl -n 200` as root.

The same source was also associated with multiple reverse-DNS warnings. Although such warnings do not independently establish malicious activity, their presence alongside extensive password-guessing activity and a successful privileged-account login warrants immediate investigation.

This risk should be prioritised because it affects an authentication control protecting a potentially critical backup asset. A successful login following a large volume of failures may indicate credential compromise, although the available evidence does not conclusively prove that the login was unauthorized.

2.3 Proposed defensive response

A layered response should be used to investigate the suspicious login, strengthen SSH security and improve future detection.

The first priority should be to investigate the accepted login from "203.0.113.89". The organisation should check whether it matched an approved administrative or maintenance activity. Relevant authentication, sudo, audit and backup-system logs should be preserved and reviewed. The investigation should examine the commands executed, files accessed, SSH keys added, scheduled tasks created and any changes made to backup configurations.

If the login cannot be confirmed as legitimate, the organisation should terminate any remaining sessions linked to the account and temporarily block the source IP address. The password and SSH keys for the backup account should also be changed. However, this should be coordinated with the backup team to prevent scheduled backup jobs from failing. Recent backups should also be checked to confirm that they remain complete and recoverable.

SSH access to backup01 should then be restricted to approved management networks, such as an administrative VPN or jump host. Password-based authentication should be disabled where possible and replaced with managed SSH keys. Multi-factor authentication should also be considered for administrative users. Direct remote login to the root account should be disabled, and SSH access should be limited to authorised users.

The purpose of the backup account should also be reviewed. If it is only used by an automated backup service, interactive login should be disabled. If administrators need to manage backups, they should use individual named accounts rather than sharing the backup account. Their sudo permissions should be limited to the commands required for their roles.

Authentication logs should be forwarded to a central monitoring system. Detection rules should consider the source IP address, username, hostname and time of each event. Alerts could be generated when a source produces many failed attempts within a short period, targets several usernames or successfully logs in shortly after repeated failures. Attempts involving privileged accounts such as backup or root should be treated as higher priority.

The organisation should also monitor for password-spraying attacks by counting failures against the same account across multiple IP addresses. This is important because an attacker may rotate source addresses to avoid detection rules that only monitor individual IP addresses.

2.4 Expected security benefits

The proposed response would reduce the likelihood of compromise by removing password-based SSH authentication and restricting network access to trusted management paths. It would reduce potential impact by preventing direct root login and limiting the privileges available to service and administrative accounts.

Centralised event correlation would improve detection by linking failed authentication attempts, invalid usernames, reverse-DNS warnings, and successful logins. This approach provides a more meaningful risk signal than treating a high number of failures as a risk in isolation. Centralised logging would also support forensic investigation by preserving authentication methods, username, source address, process identifier, session information, and sudo activity.

2.5 Limitations and residual risks

IP-based blocking is not sufficient as a standalone control because attackers may rotate source addresses. It may also incorrectly affect legitimate users operating behind shared NAT. Consequently, approved management addresses should be allowlisted and IP-based controls should be combined with account-based and network-based detection.

Disabling password authentication and introducing multi-factor authentication may disrupt existing administrative procedures or legacy automation. Service accounts should therefore be migrated carefully to managed keys or workload identities, with appropriate key rotation and expiry controls.

The reverse-DNS warnings should not independently trigger an account block because they may result from benign DNS configuration problems. Finally, the successful login from 203.0.113.89 may have been legitimate. The available authentication extract cannot establish compromise conclusively, however it provides sufficient evidence to justify immediate verification, credential review, and strengthened authentication controls.

Appendix

Appendix A - Full Event Classification Counts

Event Type	Count	% of 12,000 Lines
Failed Password	5176	43.1%
Accepted Password	1859	15.5%
Session Open	1441	12.0%
Session Closed	1046	8.7%
Connection Closed (preauth)	752	6.3%
Invalid User	751	6.3%
Maximum Authentication Attempts Exceeded	640	5.3%
Sudo Command	255	2.1%
Possible break-in warning	80	0.7%

Appendix B - Asset-Focused Risk Matrix

Finding or risk to asset	Python-Verified Evidence	Likelihood	Impact	Rationale, response & uncertainty
R1. Possible unauthorized SSH access following repeated password attempts. An unauthorized session could expose, alter or delete backup data, or give an attacker a starting point for further access.	Our Python results show that 203.0.113.89 generated 951 failed attempts, 42 reverse-DNS warnings and then 1 accepted password. 203.0.113.88 generated 1,250 failures and 38 warnings. The top four sources generated 77.3% of all failures.	High	Very high	Rationale: the combination of concentrated failures, warnings and an accepted password makes this the most urgent finding. Response: validate the accepted session, preserve logs and restrict the source if it is not trusted. Uncertainty: the accepted login may have been legitimate, and the log does not show account ownership, commands, source ownership or data access.
R2. Attempts against backup and privileged accounts. If a backup, root or admin account were compromised, recovery could be undermined, data could be changed or copied, and host privileges could be expanded.	The failed-username counts were backup 1,552, root 1,048 and admin 589. The log also contains 751 invalid-user lines and 255 sudo messages, showing that privileged control paths are relevant to the asset.	High	Very high	Rationale: compromise of these accounts would have a direct effect on backup confidentiality, integrity and recovery. Response: review and rotate affected credentials, prioritise MFA or SSH keys, and restrict root/password login where safe. Uncertainty: failed names do not prove that the accounts exist or were accessed, and sudo lines do not prove misuse.
R3. Possible reduction in authentication availability and response capacity. Bursts could use authentication capacity, trigger lockouts or overwhelm alerts, which could delay legitimate administration or restoration work.	Daily failures peaked at 1,072 (Jul 07), 1,276 (Jul 09) and 1,111 (Jul 11). We also counted 640 maximum-authentication-attempts-exceeded lines and 752 pre-authentication closures.	Medium	High	Rationale: repeated bursts could affect the availability of the SSH boundary or make important alerts harder to notice. Response: monitor service health and lockouts, apply rate limiting and alert on repeated bursts. Uncertainty: the log has no CPU, latency, connection-limit, lockout or service-health measurements, so we cannot confirm that an outage occurred.

R4. Username enumeration and reduced confidence in access control. Repeated guessing against service and privileged names could make future targeting easier and make it harder to separate suspicious sessions from legitimate ones.	We found 751 invalid-user lines and a broad target set including backup, root, admin, deploy, postgres and oracle. The 1,859 accepted-password lines show that the log contains mixed traffic.	Medium	High	Rationale: broad username guessing may help future attacks and makes triage less certain. Response: review account exposure, improve alerts and separate approved sessions from suspicious attempts. Uncertainty: some attempts may be automated background noise, and the log cannot show whether account names were learned or the controls were weakened.
---	--	--------	------	---

Appendix C - AI Use Declaration

ChatGPT was the only AI tool used. It was used solely for preliminary log interpretation, including identifying apparent log fields, explaining authentication events, and suggesting security-relevant questions for further investigation. No other AI tools were used.

The original prompt was:

"I am analysing these Linux authentication-log lines for a defensive cyber security exercise. Identify the fields that appear in the lines, explain the authentication events, and suggest security-relevant questions I could investigate. Treat this as preliminary analysis, not final evidence."

The AI observation was that the log contained both routine administrative activity and potentially suspicious authentication behaviour, including failed password attempts, invalid-user attempts, and repeated authentication failures. It also noted that these patterns could have benign explanations and should not be treated as proof of malicious activity without further verification.

The AI-supported output was used only as an initial observation and was not accepted as evidence on its own. The AI's observations and suggestions were then reviewed against the raw log entries and the Python-generated results.

AI influenced only the initial framing of possible authentication-log patterns. The numerical findings, tables, visualisations, risk priorities, final claims, and recommendations were determined by the group through Python-verified evidence and manual interpretation.

We ensured that the final claims were evidence-based by accepting only findings that were reproducible through Python analysis of "4_auth_log.txt". Interpretations that were not supported by the Python-verified evidence were either qualified or excluded.